

Prática Laboratorial 03 (PL03)

CURSO	UNIDADE CURRICULAR
LICENCIATURA EM ENGENHARIA INFORMÁTICA	REDES E COMUNICAÇÕES 2
DOCENTE	
NUNO FONSECA	

CONTEXT BASED ACCESS CONTROL LIST

CBAC, ou Context-Based Access Control, é uma funcionalidade de segurança usada em routers Cisco para fornecer inspeção de tráfego e filtragem dinâmica. CBAC permite que o router analise o tráfego que passa por ele, monitorizando o estado das conexões TCP e UDP. Com CBAC, podemos criar regras de firewall que permitem ou bloqueiam o tráfego com base no estado da conexão, semelhante à opção *established* nas ACLs, mas com capacidades mais avançadas.

Vantagens do CBAC**1. Inspeção de Tráfego em Tempo Real:**

- Monitoriza o tráfego que atravessa o router em tempo real, permitindo ações com base no estado das conexões.

2. Filtragem Dinâmica:

- Cria automaticamente regras temporárias para permitir o tráfego de retorno de conexões legítimas, aumentando a segurança.

3. Flexibilidade e Escalabilidade:

- Pode ser configurado para inspecionar várias aplicações e protocolos, adaptando-se às necessidades específicas da rede.

Configuração do CBAC

Aqui está um exemplo de configuração básica do CBAC num router Cisco:

1. Configurar as Listas de Controle de Acesso (ACLs) Padrão:

- Criar ACLs para definir o tráfego que será inspeccionado pelo CBAC.

```
access-list 100 permit tcp any any  
access-list 100 permit udp any any
```

Definir as Regras de Inspeção CBAC:

- Configurar regras de inspeção para monitorizar o tráfego especificado pelas ACLs.

```
ip inspect name my_inspection tcp  
ip inspect name my_inspection udp
```

Aplicar as Regras de Inspeção às Interfaces:

- Aplicar as regras de inspeção CBAC às interfaces de entrada e saída.

```
interface GigabitEthernet0/0  
ip address 192.168.1.1 255.255.255.0  
ip inspect my_inspection in  
ip inspect my_inspection out
```

```
interface GigabitEthernet0/1  
ip address 203.0.113.1 255.255.255.0  
ip inspect my_inspection in  
ip inspect my_inspection out
```

Configurar Timeouts e Limites:

- Ajustar parâmetros como timeouts e limites de sessões para controlar o comportamento da inspeção CBAC.

```
ip inspect tcp idle-time 3600  
ip inspect udp idle-time 120  
ip inspect max-incomplete high 1000  
ip inspect max-incomplete low 500
```

Explicação dos Comandos

1. **ip inspect tcp idle-time 3600:**

- **Descrição:** Este comando configura o tempo de inatividade (idle-time) para as sessões TCP inspecionadas.
- **Parâmetros:**
 - tcp: Especifica que o tempo de inatividade é para sessões TCP.
 - idle-time 3600: Define o tempo de inatividade em segundos.
- **Função:** Se não houver tráfego numa sessão TCP específica durante o tempo especificado (3600 segundos = 1 hora), a sessão é considerada inativa e será removida da tabela de inspeção. Isso ajuda a liberar recursos que não estão mais a ser utilizados.

2. **ip inspect udp idle-time 120:**

- **Descrição:** Este comando configura o tempo de inatividade (idle-time) para as sessões UDP inspecionadas.
- **Parâmetros:**
 - udp: Especifica que o tempo de inatividade é para sessões UDP.
 - idle-time 120: Define o tempo de inatividade em segundos.
- **Função:** Se não houver tráfego numa sessão UDP específica durante o tempo especificado (120 segundos = 2 minutos), a sessão é considerada inativa e será removida da tabela de inspeção. Devido à natureza sem conexão do UDP, o tempo de inatividade é tipicamente menor do que o do TCP.

3. **ip inspect max-incomplete high 1000:**

- **Descrição:** Este comando define o número máximo de sessões TCP incompletas (incomplete) antes de que o router entre num modo de proteção contra ataques.
- **Parâmetros:**
 - max-incomplete high 1000: Define o limite superior de sessões incompletas.
- **Função:** Se o número de sessões TCP incompletas (sessões onde o handshake TCP de três vias não foi concluído) atingir este valor, o router pode ativar mecanismos de proteção para prevenir possíveis ataques de negação de serviço (DoS), como o SYN flood.

4. **ip inspect max-incomplete low 500:**

- **Descrição:** Este comando define o número mínimo de sessões TCP incompletas antes de que o router saia do modo de proteção contra ataques.
- **Parâmetros:**
 - max-incomplete low 500: Define o limite inferior de sessões incompletas.

- **Função:** Se o número de sessões TCP incompletas cair abaixo deste valor, o router pode desativar os mecanismos de proteção adicionais que foram ativados quando o limite alto foi atingido. Isso ajuda a evitar falsos positivos e a garantir que o tráfego legítimo não seja bloqueado indevidamente.

Como Funciona o CBAC

1. Inspeção de Entrada e Saída:

- Quando o tráfego entra na interface configurada com regras de inspeção CBAC, o router analisa os pacotes para determinar se são parte de uma conexão estabelecida ou se são novas conexões.

2. Criação de Regras Temporárias:

- Para novas conexões iniciadas internamente, o CBAC cria automaticamente regras temporárias que permitem o tráfego de retorno. Estas regras são removidas quando a conexão termina.

3. Monitorização de Estado:

- O CBAC monitoriza o estado das conexões e aplica as regras de filtragem com base no estado atual de cada conexão. Isso permite uma filtragem mais precisa e eficaz.

Vantagens

- **Segurança Avançada:** Melhora a segurança ao monitorizar e inspecionar o estado das conexões em tempo real.
- **Redução de Ataques:** Ajuda a proteger contra vários tipos de ataques, como ataques de negação de serviço (DoS) e port scanning.
- **Gestão Simplificada:** Automatiza a criação de regras de retorno, reduzindo a necessidade de configurar manualmente regras complexas.

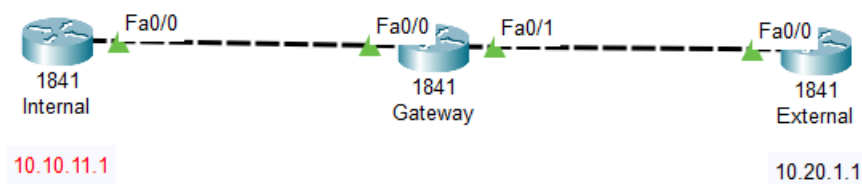
Desvantagens

- **Complexidade de Configuração:** Pode ser mais complexo de configurar em comparação com ACLs simples.

- **Recursos de Hardware:** Pode exigir mais recursos de hardware do router, como CPU e memória, especialmente em redes de alta performance.
- **Manutenção Contínua:** Requer monitorização e ajustes contínuos para garantir que as regras de inspeção estão a funcionar corretamente e de forma eficiente.

A transição de ACLs com a opção established para CBAC proporciona uma segurança mais robusta e flexível, permitindo uma melhor gestão do tráfego de rede com base no estado das conexões. Embora a configuração inicial possa ser mais complexa, os benefícios em termos de segurança e gestão tornam o CBAC uma escolha poderosa para redes que exigem um nível mais alto de controle e inspeção de tráfego.

Exemplo:



No router Gateway é colocada uma ACL a negar todo o tráfego para a zona Internal

```
ip access-list extended cbac_acl

deny ip any any
```

Aplica-se a ACL à porta fa 0/1

```
interface FastEthernet0/1

ip address 10.20.1.2 255.255.255.0

ip access-group cbac_acl in
```

Na porta fa0/0 aplica-se uma CBAC, neste caso com o nome testcbac

```
interface FastEthernet0/0  
  
ip address 10.10.11.2 255.255.255.0  
  
ip inspect testcbac in
```

A CBAC tem as seguintes regras

```
ip inspect audit-trail  
  
ip inspect name testcbac telnet timeout 3600  
  
ip inspect name testcbac tcp timeout 3600  
  
ip inspect name testcbac icmp timeout 10
```

ip inspect audit-trail

Este comando ativa a funcionalidade de auditoria para o CBAC (Context-Based Access Control).

- **Descrição:** Ativa a gravação de auditoria para todas as sessões inspecionadas pelo CBAC.
- **Função:** Regista informações sobre as sessões inspecionadas, como o início e o fim das sessões, ajudando na monitorização e auditoria de segurança. As trilhas de auditoria são úteis para rastrear e analisar atividades de rede para fins de segurança e resolução de problemas.

ip inspect name testcbac telnet timeout 3600

Este comando configura uma regra de inspeção CBAC para o protocolo Telnet com um tempo de inatividade específico.

- **Descrição:** Define uma regra de inspeção CBAC com o nome testcbac para o protocolo Telnet.
- **Parâmetros:**
 - name testcbac: Nome da regra de inspeção.
 - telnet: Especifica que a regra é para o protocolo Telnet.
 - timeout 3600: Define o tempo de inatividade em segundos (3600 segundos = 1 hora).
- **Função:** Se não houver tráfego numa sessão Telnet específica durante 3600 segundos, a sessão é considerada inativa e será removida da tabela de inspeção.

ip inspect name testcbac tcp timeout 3600

Este comando configura uma regra de inspeção CBAC para o protocolo TCP com um tempo de inatividade específico.

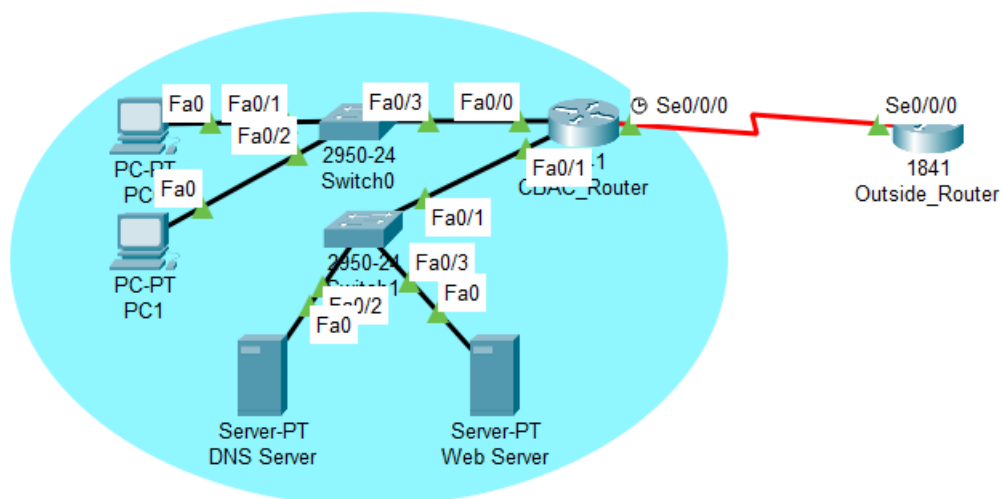
- **Descrição:** Define uma regra de inspeção CBAC com o nome testcbac para o protocolo TCP.
- **Parâmetros:**
 - name testcbac: Nome da regra de inspeção.
 - tcp: Especifica que a regra é para o protocolo TCP.
 - timeout 3600: Define o tempo de inatividade em segundos (3600 segundos = 1 hora).
- **Função:** Se não houver tráfego numa sessão TCP específica durante 3600 segundos, a sessão é considerada inativa e será removida da tabela de inspeção.

ip inspect name testcbac icmp timeout 10

Este comando configura uma regra de inspeção CBAC para o protocolo ICMP com um tempo de inatividade específico.

- **Descrição:** Define uma regra de inspeção CBAC com o nome testcbac para o protocolo ICMP.
- **Parâmetros:**
 - name testcbac: Nome da regra de inspeção.
 - icmp: Especifica que a regra é para o protocolo ICMP.
 - timeout 10: Define o tempo de inatividade em segundos (10 segundos).
- **Função:** Se não houver tráfego numa sessão ICMP específica durante 10 segundos, a sessão é considerada inativa e será removida da tabela de inspeção. Este tempo de inatividade é mais curto devido à natureza do protocolo ICMP, que é tipicamente usado para mensagens de controlo e diagnóstico.

1. Usando o packet tracer implemente um esquema idêntico ao esquema seguinte.



- a. Utilize as seguintes gamas de endereços IP para as redes internas:
 - i. Rede PCs – 192.168.1.0/24
 - ii. Rede Servidores – 192.168.2.0/24
- b. Elabore as configurações base
- c. Implemente ACL e CBAC de forma a que:
 - i. Da rede exterior não é possível aceder a nenhuma máquina/serviço das redes internas
 - ii. A partir da rede interna é possível pingar e aceder ao router Outside por telnet
 - iii. Ative o registo (audit)
 - iv. As sessões tcp, icmp e udp devem ser eliminadas ao fim 15 minutos de inatividade